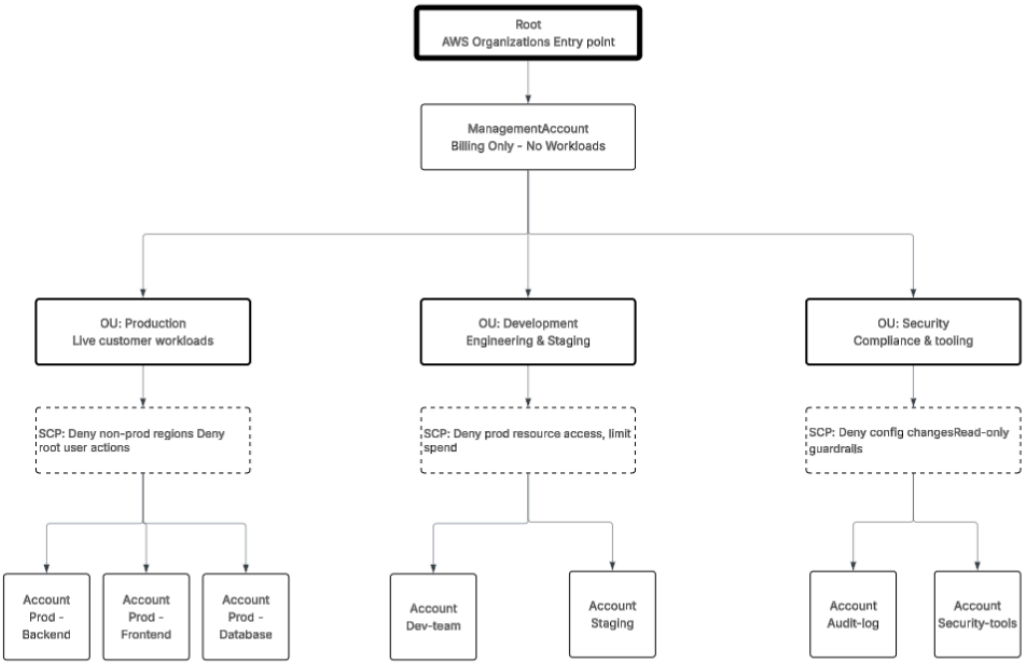
AWS Organizations structure for OluPay Ltd, showing the full hierarchy with SCPs labeled at each OU level



AWS SCP for Security OU — denies StopLogging, DeleteTrail, and UpdateTrail across all accounts to protect CloudTrail audit integrity.

security-ou-scp-cloudtrail.json

Raw

```
1  {
2    "Version": "2012-10-17",
3    "Statement": [
4      {
5        "Sid": "DenyDisableCloudTrail",
6        "Effect": "Deny",
7        "Action": [
8          "cloudtrail:StopLogging",
9          "cloudtrail:DeleteTrail",
10         "cloudtrail:UpdateTrail"
11       ],
12       "Resource": "*"
13     }
14   ]
15 }
```

simeonprimordial commented now

Author

Why would you want this SCP?, Why would you want this SCP?
The three actions this SCP blocks are precisely how an attacker covers their tracks:
StopLogging: pauses recording immediately. Every action taken after this point leaves no trace. An attacker who compromises an admin role would do this first.
DeleteTrail: permanently destroys the trail configuration. Not just paused, gone. Recovering from this is painful and leaves gaps regulators will question.
UpdateTrail: perhaps the sneakiest. An attacker could redirect your logs to a bucket they control, letting them tamper with or delete records while your team sees nothing unusual in the console.
Without this SCP, a single compromised IAM role with sufficient permissions could silently disable your entire audit infrastructure before doing anything else and you'd have no way to know what happened during that window.
With this SCP, even a fully compromised account administrator cannot touch CloudTrail. The guardrail sits above IAM entirely, at the Organizations level, and cannot be overridden from inside the account. That's the point.

AWS SCP for Security OU — denies StopLogging, DeleteTrail, and UpdateTrail across all accounts to protect CloudTrail audit integrity.

security-ou-scp-cloudtrail.json

Raw

```
1  {
2    "Version": "2012-10-17",
3    "Statement": [
4      {
5        "Sid": "DenyDisableCloudTrail",
6        "Effect": "Deny",
7        "Action": [
8          "cloudtrail:StopLogging",
9          "cloudtrail:DeleteTrail",
10         "cloudtrail:UpdateTrail"
11       ],
12       "Resource": "*"
13     }
14   ]
15 }
```

simeonprimordial commented now

Author

Why would you want this SCP?, Why would you want this SCP?
The three actions this SCP blocks are precisely how an attacker covers their tracks:
StopLogging: pauses recording immediately. Every action taken after this point leaves no trace. An attacker who compromises an admin role would do this first.
DeleteTrail: permanently destroys the trail configuration. Not just paused, gone. Recovering from this is painful and leaves gaps regulators will question.
UpdateTrail: perhaps the sneakiest. An attacker could redirect your logs to a bucket they control, letting them tamper with or delete records while your team sees nothing unusual in the console.
Without this SCP, a single compromised IAM role with sufficient permissions could silently disable your entire audit infrastructure before doing anything else and you'd have no way to know what happened during that window.
With this SCP, even a fully compromised account administrator cannot touch CloudTrail. The guardrail sits above IAM entirely, at the Organizations level, and cannot be overridden from inside the account. That's the point.

organizations:LeaveOrganization is particularly powerful to block because it's the escape hatch from everything else. An attacker who detaches an account from the org instantly loses all SCP restrictions, including the CloudTrail protection you just wrote. So this SCP is effectively the lock on the lock.

security-scp-deny-leave-org.json

Raw

```
1  {
2    "Version": "2012-10-17",
3    "Statement": [
4      {
5        "Sid": "DenyLeaveOrganization",
6        "Effect": "Deny",
7        "Action": "organizations:LeaveOrganization",
8        "Resource": "*"
9      }
10   ]
11 }
```

Write Preview

Leave a comment

Markdown is supported

Paste, drop, or click to add files

SCP vs IAM Policy Comparison

Feature	SCP (Service Control Policy)	IAM Policy
What it controls	defines the maximum allowed permissions (guardrails)	defines actual permissions (allow/deny actions)
Who it applies to	applies to aws accounts, users, and roles within an aws organization	applies to specific iam users, groups, or roles
Can it grant permissions ?	no – it only limits permissions	yes – it can allow or deny actions
Where it's applied	attached at organization level (root, ou, or account)	attached directly to users, groups, or roles
What overrides it	nothing overrides scp (it’s a hard boundary)	overridden by explicit deny and also restricted by scp
Effect on access	acts like a filter → even if iam allows, scp can block	grants access only if allowed and not blocked by scp
Scope	organization-wide governance	resource/user-level control

Bonus

Service Control Policy (SCP) that restricts AWS Organization accounts to operate only within the af-south-1 (Cape Town) region, enforcing data sovereignty by denying access to all other regions while allowing required global services.

aws-scp-restrict-region-af-south-1 Raw

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAllRegionsExceptCapeTown",
      "Effect": "Deny",
      "NotAction": [
        "iam:*",
        "organizations:*",
        "route53:*",
        "cloudfront:*",
        "support:*"
      ],
      "Resource": "*",
      "Condition": {
        "StringNotEquals": {
          "aws:RequestedRegion": "af-south-1"
        }
      }
    }
  ]
}
```

Write Preview

Leave a comment